

AUDITORÍA DE CIBERSEGURIDAD

Análisis de Incidentes y Controles de Acceso (Nómina)

Autor: Ing. Mauro Alejandro Guadarrama García

Ingeniero en Sistemas Computacionales

Proyecto de Portafolio

Certificado Profesional de Ciberseguridad de Google

Junio 2026

1. Introducción al Problema

Se reportó una transacción anómala en la que se realizó un pago de nómina hacia una cuenta bancaria desconocida ("FAUX_BANK"). Afortunadamente, el equipo financiero detuvo el pago a tiempo. Para prevenir futuros incidentes y descubrir cómo el atacante logró manipular el sistema financiero de la empresa, se llevó a cabo una auditoría forense cruzando la información del registro de eventos (Event Log) con el directorio de empleados activo.

2. Hoja de Trabajo: Auditoría de Controles de Acceso

Notas del Análisis (Registro de Eventos)	Evidencia del Actor de la Amenaza: • El incidente ocurrió el 10/03/2023 a las 8:29:57 AM. • Se utilizó la cuenta "Legal\Administrator" desde un dispositivo nombrado "Up2-NoGud". • La dirección IP de origen fue 152.207.255.255, la cual no coincide con las direcciones IP internas asignadas a los empleados legítimos.
Problemas Identificados (Directorio de Empleados)	Vulnerabilidades en la Gestión de Identidad: • Violación del Mínimo Privilegio: Absolutamente todos los empleados en el directorio (desde la gerente de oficina hasta los diseñadores gráficos y asociados de ventas de temporada) tienen privilegios de "Admin". Nadie debería tener acceso administrativo general salvo el personal de TI autorizado. • Cuentas Huérfanas (Falta de Offboarding): Hay registros de ex-empleados (como Joanne Phelps, cuyo contrato terminó el 31/01/2020) que continúan en el sistema con privilegios administrativos activos dos años después de su salida. • Uso de Cuentas Compartidas: El registro muestra una cuenta genérica "Legal\Administrator". Las cuentas genéricas impiden el no repudio, ya que no se puede rastrear a un individuo específico.

Recomendaciones
y Mitigación

Plan de Acción Inmediato:

- 1. Implementar Control de Acceso Basado en Roles (RBAC):**
Revocar el acceso de administrador a toda la plantilla. Asignar permisos estrictamente basados en las funciones laborales de cada empleado (Principio de Privilegio Mínimo).
- 2. Establecer un Proceso Estricto de "Offboarding":** Crear una política automatizada o un procedimiento obligatorio para deshabilitar y revocar inmediatamente las credenciales y accesos de los empleados en su último día de trabajo.
- 3. Eliminar Cuentas Compartidas:** Deshabilitar cuentas genéricas como "Legal\Administrator". Cada usuario debe tener credenciales únicas e intransferibles para garantizar la trazabilidad de las acciones (Accountability).

3. Conclusión

La auditoría reveló que el incidente no se debió a un fallo de software sofisticado, sino a una deficiente higiene en la gestión de identidades y accesos (IAM). La combinación de ex-empleados con cuentas activas, el exceso de privilegios (todos como Admin) y el uso de cuentas genéricas creó el entorno perfecto para que un actor de amenaza externa o interna manipulara el sistema de nóminas. Implementar RBAC y procesos de offboarding robustos cerrará estas brechas definitivamente.